SOC 2 Type II Report Summary — FY2026

Report identification

This document summarises the System and Organization Controls 2 (SOC 2) Type II report on the suitability of design and operating effectiveness of controls relevant to the Trust Services Criteria for Security, Availability and Confidentiality. The report period runs from 1 April 2025 to 31 March 2026. The report was issued on 15 June 2026 by an independent CPA firm registered with the AICPA peer review program. The summary is prepared for prospective customers; the full report is released under a mutual non-disclosure agreement.

This summary supersedes the FY2024 summary in its entirety. Where an earlier report is held on file by a customer, the FY2026 report is the only one that describes the control environment as it operates today.

System boundary

The system in scope is the cloud email encryption service: the inbound and outbound encryption gateway, the policy engine that selects a delivery method per message, the recipient portal used where no interoperable delivery path exists, the key management plane, and the tenant administration plane through which customer administrators configure policy and review event records. Corporate information technology, the marketing website and the internal customer relationship system are outside the boundary.

Subservice organisations are treated under the carve-out method. Infrastructure hosting, managed key storage and the workforce identity provider are carved out; the complementary subservice organisation controls expected of each are listed in Appendix B. Customers are expected to obtain and review those providers' own reports as part of their supply chain assessment.

Trust Services Criteria coverage

The Common Criteria CC1.1 through CC9.2 are addressed in full. Availability criteria A1.1 through A1.3 are addressed against the published service commitment of 99.95% monthly uptime for the Enterprise plan. Confidentiality criteria C1.1 and C1.2 address classification, handling, retention and disposal of message content and metadata. Processing Integrity and Privacy criteria are not within the scope of this report; conformance to ISO/IEC 27018:2019 is attested separately.

Control activities and test results

Criterion	Control activity	Result
CC6.1	Access to production requires federated sign-in with a hardware-backed second factor; standing access is reviewe	No exceptions noted.
CC6.6	Administrative sessions to production are brokered through a recorded access path; direct network reachability is r	No exceptions noted.
CC6.7	Message bodies, attachments and metadata at rest are encrypted with AES-256-GCM under per-message data ke	No exceptions noted.

Criterion	Control activity	Result
CC6.7	External connections require TLS 1.2 or above with forward-secret ciphe	No exceptions noted. TLS 1.0 and 1.1 are refused at ev
CC7.2	Security-relevant events are centralised, correlated and retained for 400 days, with continuous	No exceptions noted. Continuous monitoring by a 24×
CC7.3	The incident response procedure is exercised twice per period, once as a tabletop and once	No exceptions noted. Both exercises completed as a live scenario.
CC7.4	Confirmed incidents affecting a tenant are notified to that tenant's registered security contacts	No exceptions noted. Notifications issued within 72 hours of co
CC8.1	Changes are peer reviewed, statically analysed and scanned for vulnerable dependencies	No exceptions noted. All changes reviewed before merge; emergen
A1.2	Each residency zone is served from two regions in an active-active configuration with continuous	No exceptions noted. Configuration and continuous replication of tena
C1.1	Message content is classified at ingestion and handled under the retention schedule selected	No exceptions noted. Schedules selected by the tenant.
C1.2	Deletion requests are executed within thirty days and confirmed to the requesting tenant in writing.	No exceptions noted.

Independent service auditor's opinion

In the auditor's opinion, in all material respects, the controls stated in management's description were suitably designed and operated effectively throughout the period 1 April 2025 to 31 March 2026 to provide reasonable assurance that the service commitments and system requirements would be achieved based on the applicable trust services criteria. The opinion is unqualified. No exceptions were noted in the tests of controls described in Section 4 of the full report.

Incident notification commitment

Management commits that where an event has been confirmed to have affected the confidentiality, integrity or availability of a tenant's data, that tenant's registered security contacts are notified within 72 hours of confirmation. The initial notification states what is known, what is not yet known, the immediate containment position and the point of contact for follow-up. A written post-incident review is delivered within thirty days of incident closure. Events prevented by controls before impact, and events confined to internal systems without effect on tenant isolation, are not notifiable under this commitment; they are recorded and reviewed internally.

Complementary user entity controls

Achievement of the trust services criteria depends in part on controls operated by customers. Customers are responsible for: provisioning and deprovisioning their own personnel in their identity provider, and keeping the federation configuration current; configuring tenant policy, including which delivery methods are permitted to which recipient domains; enforcing a second factor on their own administrators; reviewing the event records exported from the tenant plane on a cadence aligned to their own obligations; and reporting suspected security events affecting their tenant through the documented channel rather than through general support.

Bridge letter

A bridge letter covering 1 April 2026 to the date of this summary is available under non-disclosure. It affirms that no material change to the control environment has occurred between the end of the report

period and the date of issue. The next Type II report is expected to cover the twelve months ending 31 March 2027.

Appendix A — principal service commitments

Commitment 1: message content is encrypted at rest and in transit using algorithms and key lengths consistent with current guidance from recognised standards bodies. Commitment 2: access to tenant content by service personnel requires a recorded business justification, federated sign-in with a second factor, and time-bounded elevation. Commitment 3: customer-initiated deletion is completed within thirty days. Commitment 4: confirmed incidents affecting a tenant are notified within 72 hours. Commitment 5: the Enterprise plan maintains 99.95% monthly uptime measured as a rolling monthly average, excluding maintenance announced at least fourteen days in advance.

Appendix B — complementary subservice organisation controls

The infrastructure provider is expected to maintain physical and environmental controls, hypervisor isolation and regional availability consistent with its own SOC 2 Type II report. The managed key service provider is expected to maintain the confidentiality and availability of wrapped key material and to log every key operation. The workforce identity provider is expected to maintain the integrity and availability of workforce authentication. Customers should obtain these providers' reports directly.